

OWASP Dependency-Check - Vulnerable Dependency Analysis

Objective

To identify vulnerable third-party libraries in a Java application using OWASP Dependency-Check and analyze the associated security risks.

Tools Used

- OWASP Dependency-Check 12.2.2
- Java 26
- Git
- WebGoat (Vulnerable Application)

Project Overview

Third-party libraries are widely used in modern software development. Vulnerabilities in these dependencies can expose applications to security risks such as Cross-Site Scripting (XSS), Remote Code Execution (RCE), privilege escalation, and data leakage.

OWASP Dependency-Check is an open-source Software Composition Analysis (SCA) tool that scans project dependencies and identifies publicly disclosed vulnerabilities using CVE databases.

Procedure

Step 1: Verify Prerequisites

```
java -version
```

```
git --version
```

Step 2: Install OWASP Dependency-Check

```
dependency-check.bat --version
```

Step 3: Download Vulnerable Project

```
git clone https://github.com/WebGoat/WebGoat.git
```

Step 4: Run Dependency Scan

```
dependency-check.bat --noupdate --scan C:\VulnProject\WebGoat --format HTML --out C:\VulnProject\Report
```

```
[INFO] Analysis Started
[INFO] Finished Archive Analyzer (0 seconds)
[INFO] Finished File Name Analyzer (0 seconds)
[INFO] Finished Jar Analyzer (0 seconds)
[INFO] Finished Central Analyzer (2 seconds)
[INFO] Finished Dependency Merging Analyzer (0 seconds)
[INFO] Finished Hint Analyzer (0 seconds)
[INFO] Finished Version Filter Analyzer (0 seconds)
[INFO] Created CPE Index (0 seconds)
[INFO] Finished CPE Analyzer (1 seconds)
[INFO] Finished False Positive Analyzer (0 seconds)
[INFO] Finished NVD CVE Analyzer (0 seconds)
[INFO] Finished RetireJS Analyzer (1 seconds)
[WARN] Sonatype OSS Index Analyzer disabled due to missing credentials. Authentication with token is now required, and OSS Index is migrating to Sonatype Guide OSS Index. See https://dependency-check.github.io/DependencyCheck/analyzers/oss-index-analyzer.html for more information on authentication with Sonatype Guide OSS Index.
[INFO] Finished Vulnerability Suppression Analyzer (0 seconds)
[INFO] Finished Known Exploited Vulnerability Analyzer (0 seconds)
[INFO] Finished Dependency Bundling Analyzer (0 seconds)
[INFO] Finished Unused Suppression Rule Analyzer (0 seconds)
[INFO] Analysis Complete (5 seconds)
[INFO] Writing HTML report to: C:\VulnProject\Report\dependency-check-report.html
PS C:\Users\latik\Downloads\dependency-check-12.2.2-release\dependency-check\bin> start C:\VulnProject\Report\dependency-check-report.html
PS C:\Users\latik\Downloads\dependency-check-12.2.2-release\dependency-check\bin> |
```

Step 5: Generate Report

The scan generated an HTML report containing vulnerable dependencies, CVE details, and severity ratings.



Dependency-Check is an open source tool performing a best effort analysis of 3rd party dependencies. False positives and false negatives may exist in the analysis performed by the tool. Use of the tool and the reporting provided constitutes acceptance for use in an AS IS condition, and there are NO warranties, implied or otherwise, with regard to the analysis or its use. Any use of the tool and the reporting provided is at the user's risk. In no event shall the copyright holder or OWASP be held liable for any damages whatsoever arising out of or in connection with the use of this tool, the analysis performed, or the resulting report.

[How to read the report](#) | [Suppressing false positives](#) | [Getting Help: github issues](#)

Project:

Scan Information ([show all](#)):

- dependency-check version: 12.2.2
- Report Generated On: Thu, 25 Jun 2026 10:46:32 +0530
- Dependencies Scanned: 93 (90 unique)
- Vulnerable Dependencies: 9
- Vulnerabilities Found: 43
- Vulnerabilities Suppressed: 0
- ...

Summary

Summary of Vulnerable Dependencies ([click to show all](#))

Dependency	Vulnerability IDs	Package	Highest Severity	CVE Count	Confidence	Evidence Count
bootstrap.min.js		pkg.javascript/bootstrap@3.1.1	MEDIUM	8		3
bootstrap.min.js		pkg.javascript/bootstrap@3.1.1	MEDIUM	8		3
jquery-1.10.2.min.js		pkg.javascript/jquery@1.10.2.min	MEDIUM*	5		3
jquery-2.1.4.min.js		pkg.javascript/jquery@2.1.4.min	MEDIUM*	6		3
jquery-ui-1.10.4.custom.min.js		pkg.javascript/jquery-ui@1.10.4	MEDIUM	4		3
jquery-ui-1.10.4.js		pkg.javascript/jquery-ui@1.10.3	MEDIUM	4		3
jquery-ui.min.js		pkg.javascript/jquery-ui@1.12.1	MEDIUM	4		3

Scan Results

- Dependencies Scanned: 93
- Unique Dependencies: 90
- Vulnerable Dependencies: 9
- Vulnerabilities Found: 43

Vulnerable Libraries Identified

- Bootstrap 3.1.1
- jQuery 1.10.2
- jQuery 2.1.4

- jQuery UI 1.10.3
- jQuery UI 1.10.4
- jQuery UI 1.12.1

Risk Analysis

The identified libraries contain known vulnerabilities that may allow:

- Cross-Site Scripting (XSS)
- Client-side code injection
- Data manipulation
- Unauthorized execution of malicious scripts

Mitigation Recommendations

- Upgrade outdated libraries to supported versions.
- Remove unused dependencies.
- Perform regular dependency scans.
- Integrate dependency scanning into the CI/CD pipeline.
- Monitor newly published CVEs affecting project dependencies.

Learning Outcomes

- Learned how to install and configure OWASP Dependency-Check.
- Performed dependency vulnerability assessment on a real application.
- Generated and analyzed an HTML vulnerability report.
- Identified vulnerable third-party components and their associated risks.
- Understood the importance of software supply-chain security.

Conclusion

OWASP Dependency-Check successfully identified vulnerable third-party libraries used by the application. The scan highlighted multiple outdated dependencies with known security issues, demonstrating the importance of regular dependency assessment and timely remediation.